

Reporte Ejecutivo de Gestión de Riesgos

Cable Sur S.A. — Sistema SIGA (Gestión de Abonados) | Dirigido al Directorio

Elaborado por: Gonzalo Carbajal — Responsable de Seguridad de la Información (rol asignado para este análisis) | Fecha: Septiembre de 2026

1. Resumen Ejecutivo

Como parte del seguimiento a la auditoría externa reciente, se realizó un relevamiento inicial de riesgos de seguridad de la información sobre el sistema SIGA, que administra la totalidad de los abonados, la facturación y la cobranza de Cable Sur. Se identificaron **8 riesgos**, de los cuales **1 es de nivel Crítico** y **3 son de nivel Alto**, concentrados principalmente en el manejo de accesos de terceros, el tratamiento de datos financieros de abonados, y la continuidad operativa del datacenter propio. Se definieron 3 planes de acción concretos, con responsable, presupuesto y fecha de cumplimiento, sobre los riesgos de mayor severidad.

Sobre la naturaleza de las amenazas externas: así como el lobo feroz no atacó a Caperucita Roja de frente, sino disfrazado de su abuela para ganarse su confianza y acceder a lo que no le correspondía, los atacantes reales rara vez tocan la puerta principal: explotan accesos legítimos mal controlados (como el acceso permanente del proveedor de software, riesgo R01) o se infiltran a través de terceros de confianza (integraciones de marketing y cobranza, riesgo R04). El directorio debe entender que el mayor riesgo no es "que entren", sino "que entren disfrazados de alguien autorizado".

2. Top 5 Riesgos por Nivel

#	Riesgo	Categoría	Nivel	Tratamiento
R01	Acceso privilegiado sin restricciones del proveedor de software	Confidencialidad / Terceros	Crítico	Mitigar
R02	Almacenamiento inseguro de datos de tarjetas (PCI-DSS)	Confidencialidad / Legal	Alto	Mitigar
R04	Exposición de datos vía integraciones con terceros	Confidencialidad / Cadena de suministro	Alto	Mitigar
R06	Riesgo físico/ambiental por datacenter propio sin redundancia	Disponibilidad / Continuidad	Alto	Mitigar
R03	Manipulación/fraude en habilitación remota de decodificadores	Integridad / Operativo	Medio	Mitigar

3. Estado de los Planes de Acción

Riesgo	Plan de acción	Responsable	Vencimiento	Presupuesto	Estado
R01	Implementar acceso privilegiado seguro (PAM) para el proveedor	Gerente de IT	30/11/2026	USD 8.000	Planificado
R02	Migrar a tokenización PCI-DSS de datos de tarjeta	CISO	28/02/2027	USD 15.000	Planificado
R06	Plan de Continuidad de Negocio y backup off-site	Gerente de IT/Infraestructura	15/01/2027	USD 6.000/año	En progreso (10%)

4. Recomendaciones Prioritarias

Defensa en profundidad — la analogía de los 3 cerditos: ningún control aislado alcanza. El cerdito de la casa de paja y el de la casa de madera cayeron ante el lobo; solo la casa de ladrillo resistió. De la misma forma, el plan de tratamiento propuesto combina *múltiples capas*: controles técnicos (gestión de accesos privilegiados, tokenización de tarjetas), controles administrativos (revisión periódica de permisos, políticas de proveedores) y controles físicos/de continuidad (redundancia del datacenter, backups off-site). Ninguna de estas capas por sí sola —como ninguna de las casas por sí sola— es capaz de contener un incidente serio.

1. **Prioridad 1 — Acceso del proveedor (R01):** implementar un esquema de acceso privilegiado (PAM) con autenticación multifactor y grabación de sesión antes de fin de año. Es el riesgo de mayor severidad del registro.
2. **Prioridad 2 — Datos de tarjetas (R02):** migrar a tokenización certificada PCI-DSS; la exposición actual implica riesgo legal y reputacional directo ante abonados y entidades bancarias.
3. **Prioridad 3 — Continuidad del datacenter (R06):** definir un sitio de contingencia y automatizar backups fuera de sitio.
Recomendación estructural: los centros de datos nunca deben ubicarse junto a cocinas ni debajo de instalaciones con agua (piletas, baños, cañerías), dado el riesgo de incendio e inundación respectivamente — una condición básica de continuidad que debe verificarse en la ubicación física actual y en cualquier sitio alternativo que se evalúe.
4. **Prioridad 4 — Integraciones de terceros (R04):** centralizar la gestión de credenciales (vault de secretos) usadas por Mailchimp, Braze, Zapier y Apigee, con rotación periódica.
5. **Prioridad 5 — Gobierno de riesgos continuo:** institucionalizar la revisión trimestral del registro de riesgos en SimpleRisk, con reporte al directorio, en lugar de tratarlo como un ejercicio único post-auditoría.

Reporte generado a partir del registro de riesgos en SimpleRisk — Cable Sur S.A. (nombre ficticio) — Uso interno / Directorio